Nhill 2.1 — Security

Français : ../fr/securite.md

This document summarises the Nhill 2.1 security model, what changed since 0.1.0 and what the operator must do. The detailed analysis, with evidence and sources, is in the security audit; the 0.1.0 internal audit (evidence through tests) is kept in `docs/securite.md` (French).

> Nhill has had **no external audit and no penetration test**. The measures described reduce risk; they do not guarantee the absence of vulnerabilities.

1. Principles

- **The server decides**: roles, permissions, subscription, limits and supervisor approvals are checked on the server for every route. Hiding a button is never a security measure.
- **Isolation by the database**: forced RLS on the 30 business tables; the application role owns no object and does not bypass RLS; a violation returns 404.
- **No secret in the applications or the repository**: no database credentials, no Supabase key (`service_role` is never used), no provider secret.
- **An identifier is not an authorisation**: neither a business's identifier, nor its renewable code, nor a receipt identifier gives access to anything.
- **Traceability**: append-only audit log, visible to the business.

2. Passwords and authentication (2.0, extended in 2.1)

Item	Rule	Rationale
Minimum length	**8 characters** for every account (creation, invitation, change, console, reset, replacement of a temporary password)	project requirement; NIST SP 800-63B-4 sets 8 with multi-factor authentication and recommends 15 for a password used alone (§ 3)
Validation	the same C++ function in the applications (before sending) and in the server (decision)	one rule, which a modified client cannot bypass
Refused passwords	list of common passwords (40 entries: "12345678", "password", "azerty123", "kinshasa"…), same as the e-mail, repetitive	NIST: refuse known-compromised or expected passwords
Composition rules	**none** (no forced digits or symbols)	NIST: composition rules do not improve real security
Periodic change	**none**; change required only after compromise	NIST: periodic expiry leads to weak passwords
Storage	Argon2id (libsodium, 3 passes, 64 MiB), never in plain text, never in logs	—
Display	show/hide button in every field	fewer typing errors, allows passphrases

Item	Rule	Rationale
Attempts	limited in the database (sign-in: 8 per 15 min per e-mail, 40 per IP address; console: 5 per account, 20 per IP; forgotten password: 3 code requests per hour per address, 10 per IP; 10 code checks per 15 min per address, 20 per IP; 5 wrong codes cancel the code)	slows guessing attacks
Sessions	opaque tokens, 15-minute access, 30-day refresh with rotation and reuse detection; password change = other sessions closed; reset (code or administrator) = all sessions closed	—
Two-factor authentication	**mandatory for Nhill Console** (TOTP); **not imposed** on businesses	the console gives access to the whole platform: this essential protection is kept

3. Accepted risk: 8 characters

The 8-character minimum is a project requirement. For a password used **without** a second factor, NIST SP 800-63B-4 (§ 3.1.1.2) recommends at least 15 characters. Since business accounts have no second factor, the risk of online guessing is offset by attempt limiting and the blocklist, and the risk of offline cracking (after a database leak) by Argon2id. **The product owner must record this decision** (decision log) and review it when optional two-factor authentication becomes available to owners.

Advice given to users (application, website, FAQ): a short sentence rather than a word, a password used only for Nhill, a password manager.

4. Security changes in 2.0

Change	Effect
Unified 8-character rule (14-character console rule removed)	consistency; console TOTP kept
Larger blocklist (common 8-character passwords)	offsets the change from 10 to 8
`X-Forwarded-For`: rightmost entry	a client can no longer choose the address seen by rate limits behind a proxy that appends the header
Debian 13 packages built against Debian's Qt	Debian's Qt security fixes apply (0.1.0 bundled Qt 6.4.2)
Activity log: technical fields hidden	fewer internal identifiers displayed
Website: separate database and roles, insert-only web role	a website compromise exposes neither the application nor the submissions already received

4a. Security changes in 2.1

Change	Effect
"Remember me": the refresh token (never the password) is kept by QtKeychain — Windows Credential Manager (DPAPI, current user), Android Keystore (non-exportable RSA-2048 key, data encrypted with AES-GCM), Secret Service or KWallet on Linux	when no secure storage is available, the session is **not** remembered: no plain-text fallback. The box is unticked by default; "Sign out" erases the entry

Change	Effect
QtKeychain 0.17.0 built from its official source, verified commit (875f77d9…); linked statically on Windows and Android	no third-party DLL next to the application (no DLL substitution); every Windows executable is checked (CredReadW/CredWriteW/CredDeleteW imports)
Temporary password given by an establishment administrator	limited to members of **their** establishment (`users.manage`), not the owner, not oneself, not an account shared with another establishment; 12 random characters, Argon2id, shown once; valid 72 h; sign-in only leads to the required change; the member's sessions are closed; action logged without the password
Required change	signing in with a temporary password only yields a one-time ticket (15 min, SHA-256 hashed); the new password must follow the rule and differ from the temporary one
Forgotten password by e-mail (owner, administrator, account of several establishments)	8-digit code, hashed with HMAC-SHA-256 under a server key derived from `NH_SECRET_KEY`, valid 20 min, 5 attempts; a new request cancels the previous one; the same 202 answer whether the address exists or not; the code is encrypted in the outbox only until it is sent, then erased
SMTP delivery (libcurl)	TLS required (smtps or STARTTLS) with certificate and host name checks; `NH_SMTP_TLS=off` refused except for a local relay; relay password read from a mode-600 file, never logged; headers protected against injection

Known limits: Windows Credential Manager keeps the entry after uninstalling as long as the user has not signed out; an Android device without a screen lock protects the Keystore less; 2.0 applications do not handle the required change (update the devices before using the reset by an administrator).

5. Known dependency vulnerabilities

Dependency	Advisory	Status	Action
cpp-httplib 0.14 (Ubuntu 24.04 / Debian package)	CVE-2025-46728, CVE-2025-53629 (memory exhaustion, CVSS 7.5)	mitigated by Caddy (`request_body max_size`)	**priority 1**: move to cpp-httplib ≥ 0.23.0, rerun the server tests
Bundled Qt 6.4.2 ("debian-13-embedded" variant)	CVE-2024-39936 and later advisories	variant discouraged, not shipped by default	use the native packages

6. What the operator must do

Before commercial opening:

- ☐ Back up `NH_SECRET_KEY` in a vault, separately from the database backups.
- ☐ Caddy in front of the server (TLS, HSTS), server listening on `127.0.0.1` only, firewall limited to 80/443 and administration.
- ☐ Daily encrypted backups and a **restore test**; consider continuous WAL archiving (otherwise up to 24 h of data can be lost).
- ☐ Monitoring: `/health`, backup failures, certificate expiry, disk, 5xx errors.
- ☐ Console accounts: minimal role, TOTP on a personal device, long passphrase.
- ☐ Payment providers in test mode until a real control payment.
- ☐ SMTP relay configured (`NH_EMAIL_TRANSPORT=smtp`, TLS, SPF/DKIM for the sender domain) and tested: without it, owners and administrators cannot recover a forgotten password.

- [ ] Personal-data formalities in the DRC (see legal-parameters.md).
- [ ] External penetration test before a wide roll-out.
- [ ] Sign the Windows installers and the APK with the publisher's certificates.

In operation: keep the system and Nhill packages up to date; watch the security advisories of cpp-httplib, Qt, libsodium, libpqxx, PostgreSQL; rotate credentials after an administrator leaves.

7. Reporting a vulnerability

Reporting address: **to be defined by the creators** (for example `security@<domain>`, published on the website and in a `security.txt` file). Commitments to set: acknowledgement, fix delay, credit to finders. Do not publish exploitable details before a fix.